



PROJECT HANDOVER

Pou Hono

The registration website for NZ Tech Week 2027
SACTH (South Auckland Creative Tech Hub) & The Cause
Collective

Version	1.1
Date	5 October 2026
Prepared by	Yahya El-Saddik
Codebase	GitHub repository PouHonoSite : main at e0700be plus the 14 fix branches in section 15
Status	Feature-complete and security-reviewed; fixes awaiting merge; not yet on production hosting

Contents

Part A is written for SACTH and The Cause Collective and needs no technical knowledge. Part B is a reference for whoever maintains or hosts the website next.

PART A — OVERVIEW FOR SACTH & THE CAUSE COLLECTIVE

- 1 Summary
- 2 What has been delivered
- 3 How it works
- 4 Keeping the data safe
- 5 Hosting: how it runs today, and how SACTH takes ownership
- 6 Before going live: actions for you
- 7 Known limitations and recommended next steps
- 8 Not included in this project
- 9 Contacts and ownership

PART B — TECHNICAL REFERENCE

- 10 Architecture and file map
- 11 Database
- 12 Access control and API reference
- 13 Setup, configuration and operations
- 14 Making common changes
- 15 Repository status

APPENDICES

- A Screenshots
- B Event-day check-in guide for staff

1 Summary

Pou Hono is the registration website for NZ Tech Week 2027, run by SACTH and The Cause Collective for South Auckland schools, youth groups and individuals.

A **teacher** registers their class and is given two things: a link and QR code to share with their students, and a private link to their own class portal. **Students** open the shared link and register themselves, and they are grouped under their teacher's class automatically. Teachers can also type students in themselves. **Individuals** who are not part of a school group can register on their own. **SACTH staff** see everything in a password-protected admin dashboard and use it to check classes in on the day.

Why it was built in-house

The website collects children's names, ages, year groups and allergy or health information. Rather than putting that into a third-party sign-up service, Pou Hono keeps all of it in a single database file that sits with the website itself. Nothing is sent to an outside data service. This is the **data sovereignty** reason the project exists, and it shaped most of the design decisions in this document.

About this version

A security and functional review on 5 October 2026 found and fixed 15 issues, plus one tidy-up. The fixes are on separate branches on GitHub, waiting for the development team to review and merge them (section 15). **This document describes the website with those fixes merged.**

Where things stand

Done

- Teacher, student and individual registration
- Shareable links and QR codes
- Teacher class portal
- Admin dashboard with filters, check-in, editing and removing classes and students, and resetting teacher links
- Security review: separate student and teacher links, expiring admin sign-ins, input limits, browser protections
- Four languages (draft translations)
- Branding, logos and event photo gallery

Needed before launch

- Proper hosting (see section 5). **Vercel is not suitable for the database.**
- Merge the 14 fix branches (section 15)
- Confirmed event dates
- Fluent-speaker review of te reo Māori, Samoan and Tongan text
- Real admin password; demo data cleared
- Privacy and consent wording (see section 7)

2 What has been delivered

Everything below is working in the current version. Screenshots are in Appendix A.

Who	What they can do
Anyone visiting Home, FAQ	• Home page: about the event and SACTH, the five sessions (Robotics, Gaming, Programming, Computer Building, Social Media), a live count of registered classes, a \$500 prize giveaway banner, a photo gallery from past events with full-size viewing, and a map to 15 Earl Richardson Avenue, Wiri. • FAQ page with seven common questions. • The SACTH and The Cause Collective logos in the header, and a contact email in the footer.
Teachers Register page	• Three-step registration: their details (name, email, school, number of students and adults, how many students are not attending, and which of the three event days), then accepting the terms, then a confirmation screen. • The confirmation screen gives a student link and QR code to share, and a separate portal link to bookmark. • They can start adding students by hand straight away.
Teacher class portal Private link	Shows the class details, the student link and QR code again, every student signed up so far (including allergies), a form to add a student by hand, and a button to remove a student.
Students Shared link / QR	A short form: name, age, year group, allergies or health conditions (optional) and preferred session. Before submitting they agree to a short statement about how their information is used. Works well on a phone.
Individuals	Choose "I'm an Individual" on the Register page and fill in the same short form, without needing a school or teacher.
SACTH staff (admin) Admin dashboard	• Password-protected sign-in that ends after 8 hours, or straight away on logout. • Headline figures: total registrations, total students expected, total adults, most popular session. • A table of every registered class, with filters by school name, activity, year group, age range and arrival status. • Check-in: click a class's status to switch it between <i>Pending</i> and <i>Arrived</i>. • Edit or delete a class. Deleting asks for confirmation first, and also removes that class's students. • Edit or remove individual students. • Reset a teacher's portal link if it has been lost or shared by mistake. The old link stops working and the admin gets a new one to send to the teacher. • A pie chart of students by preferred session, which updates with the filters.

Languages

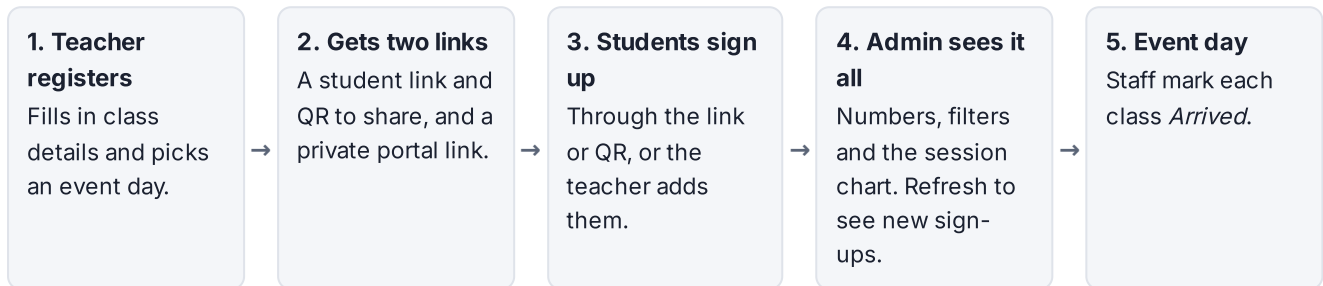
The Register, student sign-up and teacher portal pages can be switched between **English, te reo Māori, gagana Sāmoa and lea faka-Tonga** with the language menu in the header. The home page, FAQ and admin dashboard are English only.

The translations are drafts

The Māori, Samoan and Tongan text was produced with AI and **has not been checked by fluent speakers**. It must be reviewed by someone fluent in each language before the site is used with real families. See section 6.

3 How it works

The full journey, from a teacher signing up to a class arriving on the day.



Two links, two different codes

When a teacher registers, the website creates **two** long random codes for the class, one for each link:

Link	Who it is for	What it can do
<code>.../join/<student code></code>	Students. Share with the class or print as a QR code.	Adds a student to that class and shows its school name. It can't open the teacher portal or show student details.
<code>.../register/<teacher code></code>	The teacher only. Do not share.	Opens the teacher's class portal: the class list, including allergies, and adding or removing students.

There are no teacher accounts or passwords. Having the teacher code *is* the permission, so a teacher can start straight away with nothing to set up. The codes are far too long to guess. If a portal link is lost or shared by mistake, an admin can reset it from the dashboard: the old link stops working immediately, and the student link and QR code keep working.

Individuals

Behind the scenes, everyone who registers as an individual is grouped under one shared record called "Individual / Walk-in". It never appears as a class in the admin table, and it can never open a teacher portal. Individual sign-ups are still counted in the dashboard figures and the session chart.

What the admin figures mean

- **Total registrations:** the number of classes that have registered (individuals not included).
- **Total students:** the expected number of students: each class's booked number minus those not attending, plus individual sign-ups.
- **Most popular session** and the **pie chart** come from the students who have actually signed up, because a session is chosen by each student, not by the class.

4 Keeping the data safe

The website holds children's personal and health information, so access is deliberately tight.

Who can see what

Level	Can	Cannot
PUBLIC anyone	Register a class. Sign a student up, if they have a valid student link.	See student or teacher details. A student link shows the school name; the home page receives only a count.
TEACHER has a portal link	See and manage their own class only .	See or change any other class, or the individual sign-ups.
ADMIN has the password	See and manage everything.	—

Protections already in place

- **The admin password is never stored.** Only a scrambled, one-way version of it is kept (a "bcrypt hash"), so the password can't be read back out of the server's settings.
- **Admin sign-in expires and can be revoked.** Each sign-in gets its own random session, recorded on the server, which ends after 8 hours, on logout, or when the admin password is changed. A copied sign-in stops working at that point too. Logging out also clears the dashboard from the screen.
- **Limits on repeated attempts.** 10 admin login attempts per 15 minutes and 20 class registrations per hour from one internet address. Student sign-ups allow 100 an hour per class and internet address (60 for individuals), with a ceiling of 600 per address. Teachers can add 200 an hour per class. These slow automated password guessing and junk sign-ups.
- **Codes are never handed out.** A class's codes only ever appear inside its own links. The one exception is the shared code used for individual sign-ups, which is public by design and can only add a sign-up.
- **Common attacks are blocked.** Registration and student fields are checked on the server, with text limits (for example 100 characters for a name and 500 for allergies). Error messages never reveal how the website works inside. Whatever is typed is handled safely, so it cannot be used to tamper with the database (SQL injection) or to run harmful scripts on other people's screens (cross-site scripting). The student consent tick-box is checked on the form, but the website does not keep a record that it was ticked.
- **Browser protections.** The website tells browsers not to pass its addresses on to other sites, not to show it inside other sites, and to limit where scripts can load from; inline scripts and one outside script source are still allowed. The admin dashboard loads no outside code at all.
- **It fails safe.** If the admin password or secret key is missing from the settings, the public pages keep working but the admin dashboard refuses *everyone*. It never falls open.

Your responsibilities

- Keep the admin password to the smallest group that needs it, and change it if someone leaves (Part B, section 13).
- Keep the server settings file (`.env`) private. It holds the password hash and the secret key.
- Tell teachers their **portal link is private**. If one is lost or shared, reset it from the dashboard and send the teacher the new one.
- Make sure the hosting you choose is secure and backed up (section 5).

5 Hosting: how it runs today, and how SACTH takes ownership

The site is online at a free Vercel address, but only the pages are live: registrations can't work there. This section explains the current setup, where to move it, and every account SACTH needs to own.

5.1 How it is deployed today

Item	Current state (checked 5 October 2026)
Web address	<code>https://pou-hono-site.vercel.app</code> . This is a free sub-address of Vercel's own domain, so SACTH cannot buy or independently own it. A project transfer may preserve the address; confirm this with Vercel before relying on it.
Where it runs	A Vercel project, serving the pages through Vercel's global network.
Who owns it	Deployed from the GitHub repository <code>MeLware0-0/PouHonoSite</code> . The live pages are byte-for-byte identical to the current <code>main</code> (commit <code>e0700be</code> , "Deploy"). Vercel's free Hobby plan is for personal, non-commercial use. <code>[confirm account and plan with the team member who set it up]</code>
What it serves	Only the <code>public/</code> folder, as a static website: the home page, FAQ, the forms and the admin login screen all display. The server part of the website isn't running: every <code>/api/...</code> address returns Vercel's "NOT_FOUND" page.
What that means	Registering a class, student sign-up, the teacher portal, admin login and the home page counter all fail on the live site . No registration data is stored on Vercel. Server files (<code>server.js</code> , <code>.env</code> , the database) are <i>not</i> exposed.

Why Vercel can't simply be switched on for registrations

Pou Hono keeps all its data in one database file beside the website. Vercel runs server code as short-lived "serverless" functions on a **read-only file system**. The only writable space is temporary, gets wiped, and isn't shared between copies of the site. So even with the server part enabled, registrations would fail to save or quietly disappear. Vercel says this in its own guidance on SQLite. Vercel suits the pages, not the data. (Provider details in this section are from `vercel.com/docs`, `docs.railway.com`, `internetnz.nz` and `docs.github.com`, October 2026; confirm before signing up.)

5.2 What the website needs from a host

- ☐ **A Node.js server that keeps running** (version 22 or 24), not serverless functions.
- ☐ **Permanent disk storage** (a "volume") that survives restarts and redeployments, for the database file.
- ☐ **HTTPS** and a custom domain name.
- ☐ **Private settings** (environment variables) for the admin password hash and secret key.
- ☐ **Backups** of the volume, or a way to copy the database file off regularly.
- ☐ *Ideally:* servers in **New Zealand or Australia**, in line with the data-sovereignty goal.

5.3 Recommended: move to Railway

Railway runs Pou Hono as it is, with a permanent volume, HTTPS and custom domains built in. Its nearest region is **Singapore**; it has no NZ or Australian region, so the data would be held offshore. If keeping data

onshore is a must, use any NZ or Australian host that meets 5.2; the same steps apply.

1. **SACTH creates the Railway account** with an organisation email (not a developer's) and adds a payment method. A paid plan is needed for an always-on service with a volume. Invite developers as members.
2. **New project → Deploy from GitHub repo**, choosing the repository after it has moved to SACTH's GitHub (5.4). Railway runs `npm start`.
3. **Add a volume** to the service, mounted at `/data`. Choose the Singapore region before adding it, because moving a volume between regions later causes downtime. Run a single instance: the database is one file.
4. **Set the variables:** `NODE_ENV=production`, `ADMIN_PASSWORD_HASH`, `SESSION_SECRET`, `DATABASE_PATH=/data/pou-hono.db`, `TRUST_PROXY=1`, and `PUBLIC_BASE_URL=https://<your domain>`. Generate the hash and secret fresh (section 13). The last three come from the fix branches in section 15. After deploying, confirm the rate limits see real visitor addresses. Let the host set `PORT`.
5. **Clear the demo data** before the first real start (section 13).
6. **Add the custom domain** in the service's networking settings. Railway shows a `CNAME` and a `TXT` record. Add *both* at the domain's DNS provider; the domain won't verify with the CNAME alone. Railway then issues the HTTPS certificate automatically, though DNS changes can take up to 72 hours.
7. **Test end to end** on the real domain: register a test class, scan its QR code on a phone, sign up a student, check the teacher portal and admin dashboard, then delete the test class.
8. **Retire the Vercel deployment** so it can't be mistaken for the real site.

5.4 What SACTH needs to own, and how to take it over

Asset	Today	How SACTH takes ownership
Domain name	None. <code>pou-hono-site.vercel.app</code> belongs to Vercel.	Simplest: use a sub-address of an existing domain controlled by SACTH, e.g. <code>register.sacth.nz</code> if SACTH controls it. Nothing to buy; whoever manages <code>sacth.nz</code> 's DNS adds Railway's two records. Or buy a new name (e.g. a <code>.nz</code> or <code>.org.nz</code>) from any authorised .nz registrar (InternetNZ, which runs .nz, doesn't sell directly). Register it in SACTH's or The Cause Collective's legal name , never a developer's; turn on auto-renew; keep the registrar login with SACTH.
Source code (GitHub)	Repository namespace <code>MeLware0-0</code> ; confirm its owner and transfer authority.	SACTH creates a free GitHub organisation. The current owner uses <i>Settings → Transfer ownership</i> on the repository to move it there; GitHub redirects the old address. Developers stay on as collaborators. Agree code ownership and licence in writing; there is no licence file.
Hosting	Vercel; account ownership needs confirmation.	Create the Railway project under SACTH's account from the start (5.3). If Vercel is kept for anything, move the project to a SACTH-owned Vercel team with <i>Project Settings → General → Transfer Project</i> (the sender must own the source team and be a member of the receiving one). Otherwise delete it.
Admin password & secret key	Not recorded in the repository; confirm who holds development credentials.	SACTH generates its own for production, stores them in a password manager, and enters them only in the host's settings. After handover, rotate both so no developer holds live credentials.
The data	None live yet.	Once live, the data is the single database file on the volume. SACTH owns it and its backups, decides how long it's kept (section 7), and controls who can download it.
Billing & recovery	—	Every account above (registrar, GitHub organisation, Railway) uses a shared SACTH email with at least two SACTH owners, so access doesn't depend on one person.

6 Before going live: actions for you

Nothing here needs new features built. These are decisions, content and setup.

Action	Why	Who
☐ Choose hosting and deploy (section 5)	Vercel cannot keep registrations.	SACTH + developer
☐ Review and merge the 14 fix branches (section 15)	They contain the security fixes this document assumes.	Developer
☐ Confirm the three event dates	The current dates, Tuesday 18 to Thursday 20 May 2027, are placeholders .	SACTH
☐ Fluent-speaker review of te reo Māori, gagana Sāmoa and lea faka-Tonga	The current text is AI-generated and unchecked.	SACTH
☐ Set the real admin password	The brief's example password, <code>SACTH2027</code> , is publicly known and must not be used anywhere.	Developer
☐ Clear the demo data	The site creates five example schools and eighteen example children on a new database, so the dashboard can be demonstrated.	Developer
☐ Review the wording of the teacher terms, the student consent statement and the FAQ answers	These are legal and safety statements made in your name.	SACTH
☐ Confirm the \$500 prize giveaway banner on the home page	It is a public promise.	SACTH
☐ Privacy and consent (section 7)	The site collects children's health information.	SACTH
☐ Decide who holds the admin password and fill in section 9	So someone owns the system after handover.	SACTH
☐ Merge the school-name search (section 8)	It is built, but not yet part of the main version.	Developer

7 Known limitations and recommended next steps

These are the edges of what was in scope, listed so nobody is surprised by them.

Privacy and consent **PRIORITY**

The website collects children's names, ages and health information, which puts it under the **NZ Privacy Act 2020**. The following are not yet in place:

- A **privacy statement** page explaining what is collected, why, who can see it, how long it is kept and how to ask for it to be corrected or deleted. The student form has a one-paragraph statement, but there is no full policy.
- A **parent or caregiver consent** step. At the moment students agree for themselves, at any age.
- A **retention plan**: when the data will be deleted after the event, and who does it.

We recommend SACTH settle these before registrations open. Building a privacy page and a consent tick-box is a small piece of work once the wording is agreed.

Admin dashboard

- **No export or print view.** There is no CSV or Excel download, and no printable class list with allergies for the day.
- **One shared admin password**, with no individual staff accounts and no log of who changed what.
- **The dashboard loads every child's details.** To draw its figures, the dashboard downloads all students, including names and allergies, even though the figures only need ages, year groups and sessions. Trimming this is recommended once the admin student-editing feature is finalised, since that feature may rely on it.
- On smaller laptop screens the registrations table scrolls sideways to reach the Status and Actions columns.

Teachers

- Teachers **cannot change their own class details** after registering. The portal tells them to contact SACTH, and an admin makes the change.
- A teacher who **loses their portal link** has to ask SACTH, and an admin resets it. There is no "email me my link", because confirmation emails are not part of this project (section 8).

Other

- The home page map loads from Google; it receives no registration data. Everything else, including the admin chart library, is served from the website itself.
- Attempt limits are kept in memory, so they reset whenever the server restarts.
- There are **no automated tests** (changes are checked by hand), and no load testing yet (section 8).

8 Not included in this project

These were either handled separately, deliberately left out, or are built but not yet switched on.

Item	Status	Notes
School-name search on the teacher form	BUILT, NOT MERGED	The "Search your school..." box is a plain text field in the main version. A finished search over South Auckland school names exists on a separate branch (<code>schoolsearch</code>) and needs merging and testing.
Production hosting and deployment	TO DO	See section 5.
Confirmation email to teachers	NOT IN SCOPE	Handled separately. No email is sent today. Teachers must copy their links from the confirmation screen.
Load testing to 1,000 users	NOT IN SCOPE	Recommended before launch if large numbers are expected at once.
Uploading paper forms	NOT IN SCOPE	The database has space to record a file name, but no upload feature exists and no files are stored.

9 Contacts and ownership

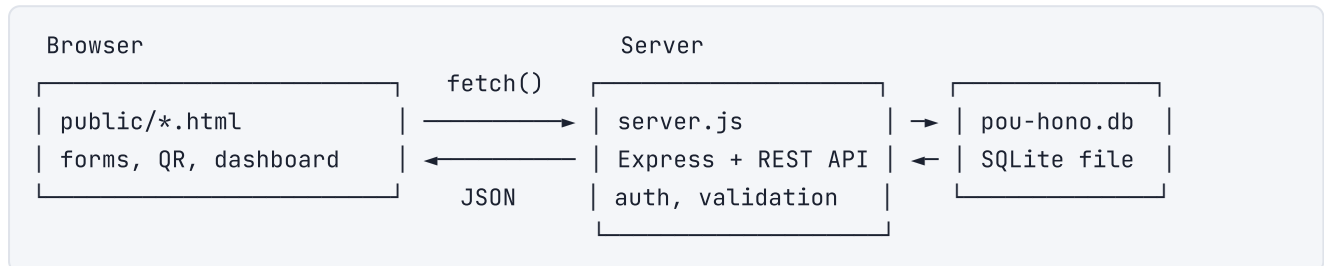
To be completed by SACTH and the developer at handover.

Role	Name and contact
Project owner (SACTH / The Cause Collective)	[name, email, phone]
Holder(s) of the admin password	[names]
Hosting account owner	[provider, account owner, billing contact]
Domain name owner	[domain, registrar, account owner]
GitHub repository owner	[account / organisation]
Technical support after handover	[name, email, support terms]
Translation reviewers	te reo Māori: [name] gagana Sāmoa: [name] lea faka-Tonga: [name]
Public contact email on the website	sacth@thecausecollective.org.nz . Confirm this is correct.

PART B Technical reference for the developer who hosts, maintains or extends Pou Hono. The repository's `README.md` and `CLAUDE.md` cover the same ground and should be kept up to date alongside the code.

10 Architecture and file map

Node.js + Express 5, a single-file SQLite database via `better-sqlite3`, and plain HTML/CSS/JavaScript served as static files. No framework, no bundler and no build step: you edit a file and reload the page.



File	Purpose
<code>server.js</code>	The entire back end: Express app, security headers, static serving of <code>public/</code> , rate limiters, the <code>requireAdmin</code> and <code>requireTeacherToken</code> middlewares, validation, every route, and the final error handler.
<code>db.js</code>	Opens the database at <code>DATABASE_PATH</code> or next to itself (WAL mode, foreign keys on), creates the schema including <code>admin_sessions</code> , adds missing columns (<code>not_attending</code> , <code>is_walk_in</code> , <code>teacher_token</code>), backfills teacher tokens, creates the walk-in container, and seeds demo data on an empty database. (The <code>token</code> -column migration for very old databases is on <code>origin/schoolsearch</code> .)
<code>public/index.html</code>	Home page: hero, live counter, sessions, prize banner, photo gallery with lightbox, map.
<code>public/register.html</code>	Teacher path (3 steps) and the entry point for the individual path.
<code>public/teacher.html</code>	Teacher class portal, served at <code>/register/:token</code> .
<code>public/student.html</code>	Student sign-up, served at <code>/join/:token</code> , or directly for individuals.
<code>public/admin.html</code>	Admin dashboard (login gate, stats, filters, table with edit, reset teacher link and delete, Chart.js pie chart).
<code>public/vendor/</code>	Self-hosted Chart.js and its licence.
<code>public/faq.html</code>	FAQ.
<code>public/nav.js</code>	Injects the shared header (logos, menu, language picker) and footer into every page.
<code>public/translations.js</code>	UI strings in <code>en</code> , <code>mi</code> , <code>sm</code> , <code>to</code> , applied via <code>data-i18n</code> and <code>data-i18n-placeholder</code> attributes.
<code>public/event-days.js</code>	The three event dates. Loaded by both Node (<code>require</code>) and the browser (<code><script></code>), so they are defined once.

<code>public/styles.css</code>	Shared styles.
<code>public/images/</code>	The SACTH and The Cause Collective logos and eight event photos.
<code>.env.example</code>	Committed template for the settings file, with the commands to generate each value.

Dependencies (`package.json`): `express`, `better-sqlite3`, `bcryptjs`, `cookie-parser`, `express-rate-limit`, `qrcode`, `dotenv`. The only browser library is Chart.js 4.4.1, self-hosted at `public/vendor/chart.umd.js` with its MIT licence.

11 Database

One SQLite file, `pou-hono.db`, created on first run next to `db.js`, or wherever `DATABASE_PATH` points (on a host, the persistent volume). It is gitignored and is the only place data lives.

registrations: one row per class (plus the walk-in container)

Column	Type	Notes
<code>id</code>	INTEGER PK	Auto-increment.
<code>school</code> , <code>contact</code> , <code>email</code>	TEXT NOT NULL	Teacher's details. <code>school</code> is display text only, not an identity.
<code>students</code> , <code>adults</code>	INTEGER	Booked numbers (1–500 and 0–200).
<code>not_attending</code>	INTEGER, default 0	How many of the booked students won't come. Head count = <code>students - not_attending</code> .
<code>session</code>	TEXT	Always <code>'NZ Tech Week 2027'</code> for public registrations. Per-student session choices live on <code>students</code> .
<code>date</code>	TEXT <code>YYYY-MM-DD</code>	Event day. Stored in this format so it sorts and compares as plain text. Public registrations must use one of the days in <code>event-days.js</code> , but admin edits may use any real date.
<code>notes</code> , <code>file_name</code>	TEXT	<code>file_name</code> is only a string. No file is stored.
<code>status</code>	TEXT, CHECK	<code>'Pending'</code> or <code>'Arrived'</code> .
<code>token</code>	TEXT UNIQUE	The student sign-up code (<code>crypto.randomUUID()</code>), used in <code>/join/...</code> links. It can only add a student. The walk-in container's token is public and is returned by <code>/api/walk-in-registration</code> .
<code>teacher_token</code>	TEXT, unique index	The teacher portal credential, used in <code>/register/...</code> links and the teacher API. Returned only in <code>portalLink</code> at registration and by the admin reset route. NULL for the walk-in container. Backfilled with a fresh value for older rows on upgrade.
<code>is_walk_in</code>	INTEGER 0/1	1 only for the shared "Individual / Walk-in" container. A partial unique index guarantees at most one; startup code creates one if absent.

students: one row per signed-up student

Column	Type	Notes
<code>id</code>	INTEGER PK	
<code>registration_id</code>	INTEGER FK	<code>ON DELETE CASCADE</code> : deleting a class deletes its students.
<code>name</code>	TEXT NOT NULL	
<code>age</code>	INTEGER, nullable	1–120 if given (individuals include adults).
<code>year_group</code>	TEXT	<code>Year 1</code> ... <code>Year 13</code> , or <code>18+</code> .
<code>allergies</code>	TEXT	Free text. Treat as sensitive health information.
<code>preferred_session</code>	TEXT	Robotics, Gaming, Programming, Computer Building, or Social Media.
<code>created_at</code>	TEXT	Set by SQLite.

admin_sessions: one row per admin sign-in

`id` (random 32-byte hex, also the signed cookie value), `created_at`, `expires_at` (8 hours on), and `password_fingerprint` (a hash of the configured password hash, so changing the password ends every session). Rows are deleted on logout; expired rows are removed on session checks or a later login.

Upgrades, the walk-in container and seed data

- **In-place upgrades:** `db.js` runs on every start. The `not_attending`, `is_walk_in` and `teacher_token` columns are in the `CREATE TABLE` and added through `addColumnIfMissing(...)`; the `admin_sessions` table is created if missing. Main does not yet migrate databases missing token; that fix is on schoolsearch. Review that migration before starting against a very old database.
- **Walk-in container:** created on startup if missing. Older databases that predate the `is_walk_in` flag have their existing "Individual / Walk-in" row marked automatically. The container cannot be edited (apart from status) or deleted through the API.
- **Seed data:** on a *completely empty* database, five example classes and eighteen example students are inserted. Real data is never touched. To start clean for production, see section 13.

12 Access control and API reference

Every route sits behind exactly one of three gates. When adding a route, decide its gate first.

- **PUBLIC** No credentials.
- **TEACHER** `requireTeacherToken` reads the **teacher token** from `Authorization: Bearer <token>` or `?token=`, looks it up by `teacher_token` only, loads that registration into `req.registration`, and scopes queries to it. A missing, unknown, student or walk-in token all return the **identical 404**.
- **ADMIN** `requireAdmin` checks the signed, httpOnly cookie `pou_hono_admin` (SameSite=Lax, Secure when `NODE_ENV=production`). Its value is a session id that must exist in `admin_sessions`, be unexpired (8 hours), and match the current password fingerprint. It is set after a bcrypt compare in `POST /api/admin/login`.

Method	Route	Gate	Purpose
POST	/api/admin/login	PUBLIC	Admin login. Rate limited to 10 attempts per 15 min per IP.
POST	/api/admin/logout	PUBLIC	Deletes the server session and clears the cookie.
GET	/api/admin/session	PUBLIC	Reports { authenticated }.
GET	/api/admin/students	ADMIN	Every student in one query.
GET	/api/registrations	ADMIN	All registrations (no token column).
PUT	/api/registrations/:id	ADMIN	Full edit, or { status } only for check-in.
POST	/api/registrations/:id/teacher-link	ADMIN	Issue a new teacher token (old portal link stops working); returns { portalLink }. 409 for the walk-in container.
DELETE	/api/registrations/:id	ADMIN	Delete a class and, through the cascade, its students.
GET	/api/registrations/:id/students	ADMIN	One class's students.
POST	/api/registrations	PUBLIC	Teacher registers a class. Returns the record plus link (student), portalLink (teacher) and qrCode. 20 per hour per IP.
GET	/api/registrations/count	PUBLIC	Home page counter (excludes walk-in).
GET	/api/registrations/token/:token	PUBLIC	School name and isWalkIn only, for the student page heading.
GET	/api/walk-in-registration	PUBLIC	The walk-in container's token, which is public by design.
POST	/api/registrations/token/:token/students	PUBLIC + token	Student sign-up with the student token. 600/hour per IP ceiling, then 100/hour per IP + class (60 for the walk-in token).
GET	/api/my-registration	TEACHER	The teacher's own record.
GET	/api/my-registration/qr	TEACHER	Student link (built from the student token) and QR code.
GET	/api/my-registration/students	TEACHER	Their students.
POST	/api/my-registration/students	TEACHER	Add a student by hand. 200 per hour per class.

DELETE	<code>/api/my-registration/students/:studentId</code>	TEACHER	Remove one of their own students only (scoped by <code>registration_id</code>).
--------	---	---------	--

Routes for the admin's per-student edit and remove were added after commit `e0700be` and should be added to this table `[route list to be added]`.

Page routes

`/join/:token` (student token) serves `student.html`. `/register/:token` (teacher token) serves `teacher.html`. An unknown token on either, including a student token on `/register/`, redirects to `/`. The public walk-in token on `/register/` redirects home too; a teacher credential wrongly assigned to that container gets a plain 404. Every other page is served statically from `public/`.

Cross-cutting behaviour

Every response carries `Referrer-Policy: no-referrer`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY` and a Content-Security-Policy. `/api` responses are `Cache-Control: no-store`. Unknown `/api` paths return a JSON 404. A final error handler returns a generic JSON message (413 for oversized bodies) and never a stack trace. Share and portal links use `PUBLIC_BASE_URL` when it is set.

Rules that must not be broken

- **Never build SQL by string concatenation.** External values are bound using `db.prepare(...)` with `?` or named placeholders. Fixed queries may have no parameters; schema SQL uses `db.exec`. Only trusted, code-defined column lists and migration identifiers are interpolated.
- **Select explicit columns** from `registrations` (see `REGISTRATION_COLUMNS`), never `SELECT *`, so a new column can't leak.
- The walk-in container is identified by `is_walk_in` via `isWalkInRegistration()`, **never** by its school name, and must never pass `requireTeacherToken`.
- In the front end, every user-supplied value inserted with `innerHTML` goes through the page's `escapeHtml` helper, or is set with `textContent`. `escapeHtml` does not escape quotes, so it must not be used inside HTML attributes.
- The student token must never grant teacher access, and `teacher_token` must never be added to `REGISTRATION_COLUMNS`.

13 Setup, configuration and operations

Run it locally

```
npm install          # Node.js 22 or 24 (20 and 22-26 supported; not 18 or 21)
cp .env.example .env # Windows: copy .env.example .env, then fill in the values
                     # below
node server.js       # or: npm start → http://localhost:3000
```

Settings (`.env` or the host's environment variables)

Variable	Value
<code>ADMIN_PASSWORD_HASH</code>	bcrypt hash of the admin password. Generate it with: <code>node -e "console.log(require('bcryptjs').hashSync(process.argv[1], 10))"</code> <code>'NewPassword'</code>
<code>SESSION_SECRET</code>	Long random string that signs the admin cookie. Generate it with: <code>node -e "console.log(require('crypto').randomBytes(32).toString('hex'))"</code>
<code>PORT</code>	Optional. Defaults to 3000. Most hosts set this automatically.
<code>NODE_ENV</code>	Set to <code>production</code> on the live server, which makes the admin cookie HTTPS-only.
<code>DATABASE_PATH</code>	Optional. Where the database file lives. Default: next to <code>db.js</code> . On a host, use the persistent volume, e.g. <code>/data/pou-hono.db</code> ; its folder must exist.
<code>TRUST_PROXY</code>	Optional. Set when running behind a host's proxy so rate limits see real visitor addresses: a hop count such as <code>1</code> , or an Express trust-proxy value. Match the proxy layout; trusted proxies must overwrite forwarding headers.
<code>PUBLIC_BASE_URL</code>	Optional. The canonical address used to build share links, portal links and QR codes, e.g. <code>https://register.sacth.nz</code> . Unset uses the request's own address.

If either secret is missing, the server starts with a warning and admin login refuses every attempt.

Routine tasks

- **Change the admin password:** generate a new hash, replace `ADMIN_PASSWORD_HASH`, restart. Every existing admin session ends automatically.
- **Rotate the cookie secret:** replace `SESSION_SECRET` and restart. This also signs everyone out.
- **A teacher has lost or leaked their portal link:** in the dashboard, use *Reset teacher link* on their class and send them the new link.
- **Clear demo data for launch:** note that deleting `pou-hono.db` does *not* give an empty site. On restart, `db.js` sees an empty database and inserts the demo data again. Either (a) **recommended:** disable the two seed blocks in `db.js` before the production server's first start, or (b) on the live site, delete the five example classes in the admin dashboard (which removes their students) and remove the two example individual sign-ups. The class seed runs only when the registrations table has zero rows; the retained walk-in container prevents reseeding even before real classes exist. The student seed also requires classes to have been seeded on that same startup and an empty students table.

- **Reset everything (development only):** stop the server and delete the configured database file (default: `pou-hono.db`) together with its `-wal` and `-shm` files. The next start rebuilds the schema and the demo data.
- **Back up:** the whole system's data is the one database file. Because it runs in WAL mode, don't just copy `pou-hono.db` while the server is running. Either stop the server first, or take a consistent copy with `sqlite3 pou-hono.db ".backup backup-YYYY-MM-DD.db"`. Use the configured database path. Schedule daily during registration; keep copies off the server.

Production checklist

- ☐ All 14 fix branches merged (section 15).

- ☐ Host with a long-running Node process and a **persistent volume**; `DATABASE_PATH` points into it (section 5). Run a single instance.

- ☐ `NODE_ENV=production`, fresh `ADMIN_PASSWORD_HASH` and `SESSION_SECRET`, `TRUST_PROXY` matched to the host's proxy layout and `PUBLIC_BASE_URL` set to the live HTTPS origin.

- ☐ HTTPS and the custom domain working. A QR code generated on the live site opens the live domain over `https://`.

- ☐ Rate limits see real visitor addresses: from two different networks, each gets its own allowance.

- ☐ Demo data cleared and automated backups running.

14 Making common changes

To change...	Edit
The event dates	<code>public/event-days.js</code> only . The form, teacher portal, validation and new seed inserts read it. The admin table formats the stored date independently. Existing registration dates, including previously seeded rows, do not change automatically; correct them separately if needed. Keep the <code>YYYY-MM-DD</code> format.
Session names	Several places must match: the <code>validSessions</code> list in <code>validateStudent</code> (<code>server.js</code>), the session choices in <code>student.html</code> , <code>teacher.html</code> and <code>register.html</code> , the session cards on <code>index.html</code> , and the matching strings in <code>translations.js</code> .
Event name (<code>NZ Tech Week 2027</code>)	The value the register form posts, the check in <code>validateRegistration</code> , and page text and translations.
FAQ	<code>public/faq.html</code> (English only).
Translated text	<code>public/translations.js</code> . Add or change every key in all four languages, because a missing key leaves the existing text unchanged, possibly in the previously selected language. Only an unrecognised language falls back to the English dictionary. Keep the "AI-generated, not reviewed" warning until a review is done.
Photos	Add files to <code>public/images/</code> and a matching <code>gallery__item</code> button in <code>index.html</code> .

Header, footer, contact email	<code>public/nav.js</code> .
Rate limits	The <code>makeLimiter(...)</code> calls near the top of <code>server.js</code> .
A new database column	Add it to <code>CREATE TABLE</code> in <code>db.js</code> and add an <code>addColumnIfMissing(...)</code> call. If it is user-facing, update <code>validateRegistration</code> / <code>cleanRegistration</code> , <code>REGISTRATION_COLUMNS</code> and the form.
A new API route	<code>server.js</code> . Copy a neighbouring route and choose its gate deliberately.
A new outside resource (script, font, embed)	Add its origin to the Content-Security-Policy in the security-headers middleware near the top of <code>server.js</code> , or the browser will block it.
A new page	A new file in <code>public/</code> , copying an existing page's structure (nav placeholder, <code>styles.css</code> , <code>nav.js</code> , plus <code>translations.js</code> if it needs the language switcher).

15 Repository status

Item	Status
<code>main</code>	The current version, at commit <code>e0700be</code> (5 October 2026). It includes all registration work (<code>registration-backbone</code> is fully merged and can be deleted), admin edit and delete, and the photo gallery.
<code>origin/schoolsearch</code>	Not merged. Adds South Auckland school-name search to the teacher form (<code>public/schools.js</code>), plus a fix that adds the <code>token</code> column when upgrading a very old database. Review, test and merge before launch.
Documentation	<code>README.md</code> , <code>CLAUDE.md</code> (rules for developers and AI assistants) and <code>.env.example</code> ; keep them current. No tests, linter or build step, by design. There is no project licence file (<code>package.json</code> says ISC); agree ownership and licensing in writing.

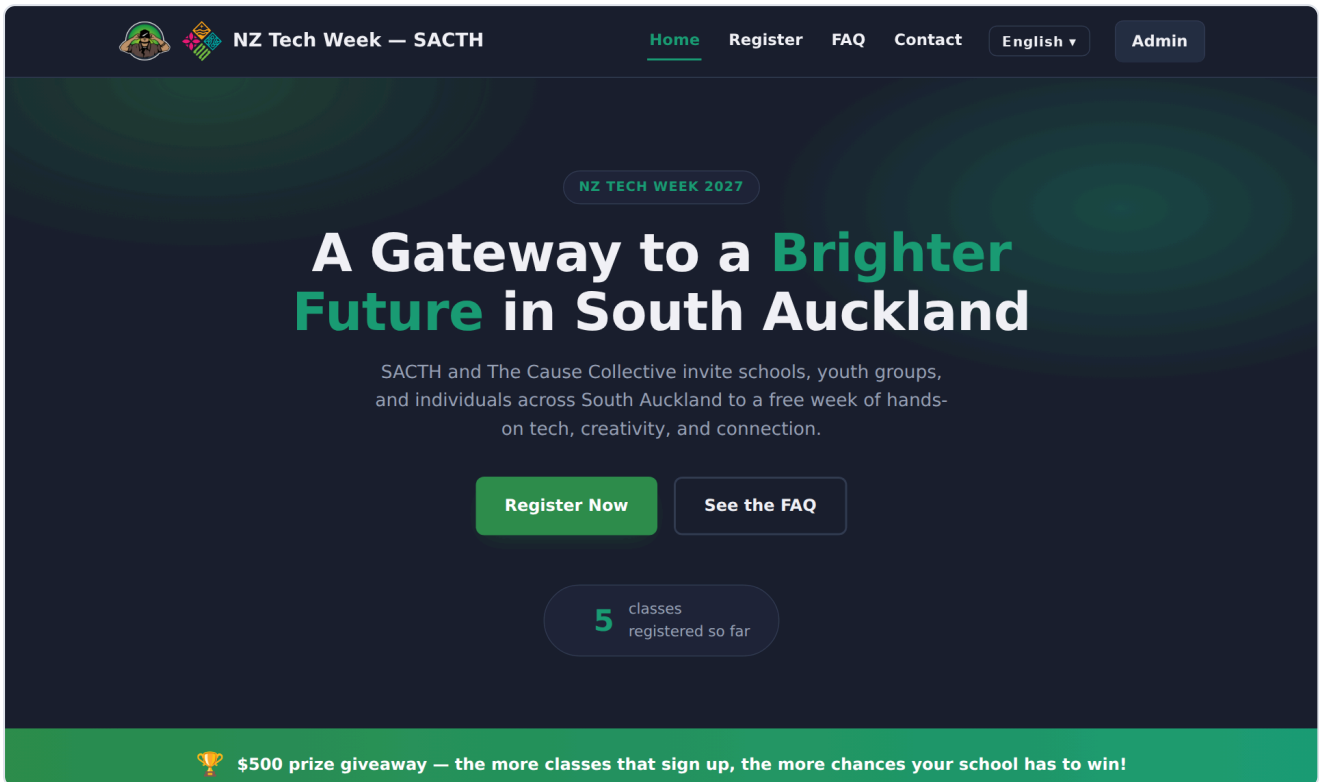
Fix branches awaiting review

From the 5 October 2026 review, pushed to GitHub for the team to review and merge. Merged in this order they apply cleanly; the combined site passed a 30-step browser test of every user journey, and a final review passed 127 server checks.

#	Branch	What it fixes
1	<code>fix/separate-teacher-portal-token</code>	The student link no longer opens the teacher portal: separate student and teacher codes.
2	<code>fix/teacher-link-rotation</code>	Admin can reset a teacher's portal link. <i>Built on 1.</i>
3	<code>fix/rate-limits-and-proxy</code>	Limits that work for whole schools on one internet address; <code>TRUST_PROXY</code> , <code>PUBLIC_BASE_URL</code> . <i>Built on 2.</i>
4	<code>fix/configurable-database-path</code>	<code>DATABASE_PATH</code> , so the database can live on a host's permanent volume. <i>Built on 3.</i>
5	<code>fix/admin-sessions</code>	Admin sign-ins expire on the server, end on logout and after a password change; logout clears the page.
6	<code>fix/input-validation-and-errors</code>	Length and type limits on registration and student fields; errors return generic messages, never internal details.
7	<code>fix/security-headers</code>	Browser security headers, including a content security policy.
8	<code>fix/self-host-chartjs</code>	The admin chart library is served from the site, not a third party.
9	<code>fix/adult-individual-age</code>	Age limit 25 → 120 so adults can register as individuals.
10	<code>fix/remove-default-admin-password</code>	The settings template no longer suggests a published password.
11	<code>fix/dependency-audit</code>	ip-address 10.7.3 and qs 6.16.0; <code>npm audit</code> clean on 5 Oct 2026. Recheck before launch.
12	<code>fix/node-version-and-package-metadata</code>	Node 22 or 24 in the README; engine ranges match the database library; <code>main</code> fixed.
13	<code>fix/home-counter-label</code>	Home page counter says "classes", which is what it counts.
14	<code>fix/remove-ds-store</code>	Removes a stray macOS file.

A Screenshots

Taken from the current version running with its demo data.



Home page.

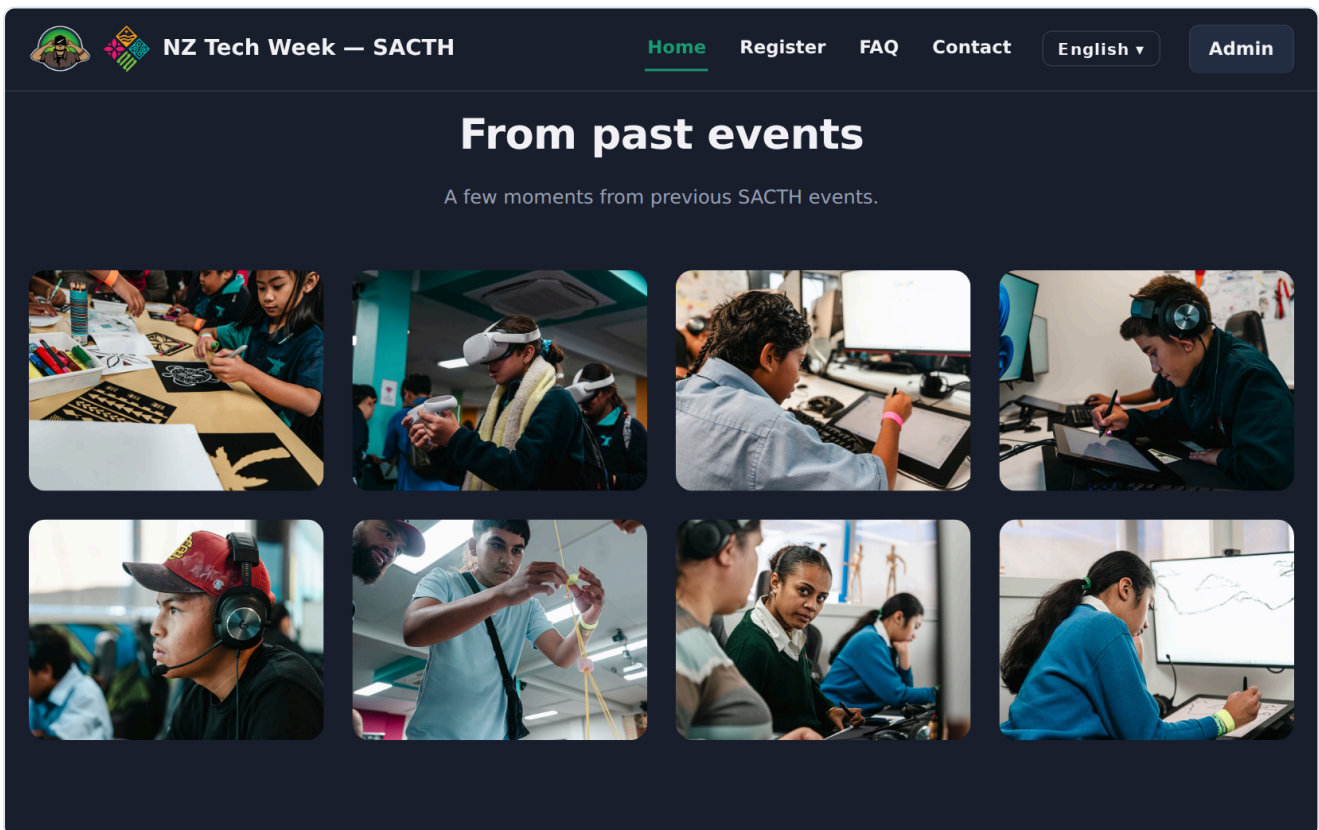


Photo gallery from past events. Each photo opens full-size.



Register: choose teacher or individual.

Teacher registration, step 1.

NZ Tech Week — SACTH

Home Register FAQ Contact English Admin

Register for Mangere College

You're joining Mangere College's NZ Tech Week 2027 visit — pick your session below.

We collect this information to plan a safe NZ Tech Week 2027 event and to let you choose a session. Your details are stored securely by SACTH and The Cause Collective and are never shared outside the event's organisation.

☐ I understand how my information will be used and agree to take part.

Your name

Age **Year group**

Allergies / health conditions (optional)

Preferred session

Student sign-up through a teacher's link.

NZ Tech Week — SACTH

Register for Mangere College

You're joining Mangere College's NZ Tech Week 2027 visit — pick your session below.

We collect this information to plan a safe NZ Tech Week 2027 event and to let you choose a session. Your details are stored securely by SACTH and The Cause Collective and are never shared outside the event's organisation.

☐ I understand how my information will be used and agree to take part.

Your name

Age **Year group**

Allergies / health conditions (optional)

The same page on a phone.



Your class portal

Mangere College

Class details

These are the details you gave us when you registered. Contact us if anything needs changing.

School name	Mangere College
Full name	A. Havili
Email	reception@mangere.school.nz
Number of students	40
Number of adults	3
Students not attending	3
Event day	Day 1 — Tuesday 18 May 2027

Student link

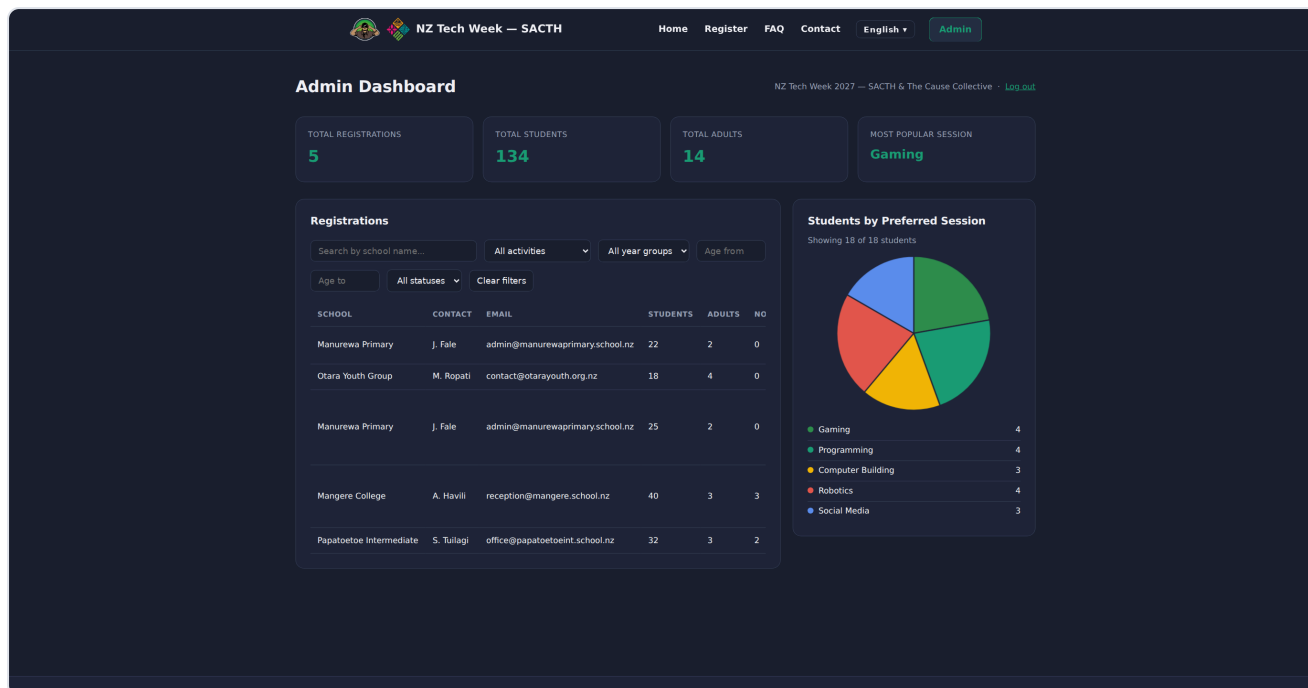
Give this link or QR code to your students so they can add their own details to your class. It is not the same as the link you are on now — keep this page's address to yourself.



<http://localhost:4008/join/80cc1637-61d9-448f-8c66-069ccf1d>

Copy

Teacher class portal: class details and student link with QR code.



Admin dashboard.

Registrations						
Search by school name... All activities All year groups Age from Age to All statuses Clear filters						
DULTS	NOT ATTENDING	EVENT DAY	STATUS	NOTES	ACTIONS	
0		Thu 20 May	Arrived	Repeat visit	Edit	Reset teacher link Delete
0		Thu 20 May	Pending	—	Edit	Reset teacher link Delete
0		Wed 19 May	Arrived	Two students need wheelchair access	Edit	Reset teacher link Delete
3		Tue 18 May	Pending	Te reo Māori support requested	Edit	Reset teacher link Delete
2		Tue 18 May	Arrived	—	Edit	Reset teacher link Delete

Registrations table: status (click to check in), Edit, Reset teacher link and Delete.

Registrations						
Search by school name... All activities All year groups Age from Age to All statuses Clear filters						
SCHOOL	CONTACT	EMAIL	STUDENTS	ADULTS		
Manurewa Primary	J. Fale	admin@manurewaprimary.school	22	2		
Otara Youth Group	M. Ropati	contact@otarayouth.org.nz	18	4		
Manurewa Primary	J. Fale	admin@manurewaprimary.school.nz	25	2		
Mangere College	A. Havili	reception@mangere.school.nz	40	3		
Papatoetoe Intermediate	S. Tuilagi	office@papatoetoeint.school.nz	32	3		

Editing a class in place.

B Event-day check-in guide for staff

One page for whoever is on the door. Print it out for the day.

Before the day

1. Make sure you can sign in: go to `[live website address] /admin.html` and enter the admin password.
2. Check the **Notes** column for anything you need to prepare, such as wheelchair access or language support.
3. Ask teachers to bring their own class list. Their portal shows each student's allergies and health notes.

When a class arrives

1. Type the school name into **Search by school name**.
2. If the school has more than one booking, check the **Event day** column to find today's.
3. Click the yellow **Pending** label. It turns green and reads **Arrived**. Click it again to undo a mistake.

Useful views

- **Who hasn't arrived yet?** Set the status filter to *Pending*.
- **A walk-in class that never registered?** Register them on the spot through the normal Register page, then mark them Arrived.
- **Numbers changed at the door?** Click **Edit** on the class, correct the student or adult numbers, and save.
- **Clear filters** resets the view.

Remember

- Sign-in lasts up to 8 hours. If the dashboard asks for the password again, sign in again; nothing is lost.
- **Delete** removes a class *and all its students* permanently. You don't need it on the day.
- Log out on shared computers when you're done.